

Cryptographic Foundations for Healthcare Systems

Giuseppe Pisano
g.pisano@unibo.it

Healthcare Data Privacy and Security

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

- 1 Cryptographic Foundations
- 2 Symmetric Encryption
- 3 Blocks, Streams, and Modes
- 4 Authentication and Hashes
- 5 Public-Key Cryptography
- 6 Signatures, Certificates, and Envelopes
- 7 Keys and Randomness

8 Putting It Together

Learning path

We move from **why cryptography is needed**, to **symmetric algorithms**, then to **blocks, streams, and modes**. After that we add **integrity**, **public-key cryptography**, certificates, envelopes, key management, and randomness.

Hospital storyline

We continue with St. Isidore Hospital. Encryption will protect EHR records, lab messages, pharmacy orders, backups, remote access, and communication with external providers.

Connection to later topics

This lesson gives the vocabulary needed to understand TLS, VPNs, secure email, authentication, digital signatures, and key-management policies.

- **Networking:** where encrypted channels are established.
- **Access management:** how keys, passwords, and identities are protected.
- **GDPR:** why confidentiality, integrity, and breach prevention matter for personal data.

Cryptographic Foundations

Section Context: Cryptographic Foundations

What we are talking about

Cryptography transforms information so that only authorised parties can read it, verify it, or trust where it came from. We start with the basic ideas before looking at specific families of algorithms.

Hospital lens

At St. Isidore, cryptography protects a lab result while it travels, a backup while it is stored, and a prescription order while the pharmacy verifies who sent it.

Notebook: Classical Encryption

Practical example

Open `lesson-02/examples/01_classical_caesar_cipher.ipynb` after the Caesar cipher slides.

What students should notice

The notebook encrypts a hospital message, then breaks it by trying shifts and observing letter patterns. The point is not that Caesar is useful; the point is that **patterns survive weak encryption**.

Kerckhoffs's Principle

Principle

The security of a cryptosystem should depend on the secrecy of the **key**, not on the secrecy of the **algorithm** [Kerckhoffs, 1883].

Hospital example

St. Isidore should not rely on a vendor's secret home-made encryption method. It should rely on well-studied algorithms and protect the hospital's keys carefully.

What Cryptography Provides

Core services

Cryptography can support **confidentiality**, **authentication**, **integrity**, and in some systems **anonymity**.

- **Confidentiality**: hiding content from unauthorised readers.
- **Authentication**: verifying identities or sources.
- **Integrity**: detecting unauthorised modification.
- **Anonymity**: reducing linkability to a person or communication path.

Healthcare Example: One Lab Result

Hospital example

A potassium result moves from the laboratory system to the EHR. Cryptography can keep the value private, prove it came from the lab, detect changes, and help prevent replay of an old result.

Takeaway

Encryption is not only about secrecy. Clinical systems also need authenticity, integrity, freshness, and correct ordering.

Encryption and Decryption

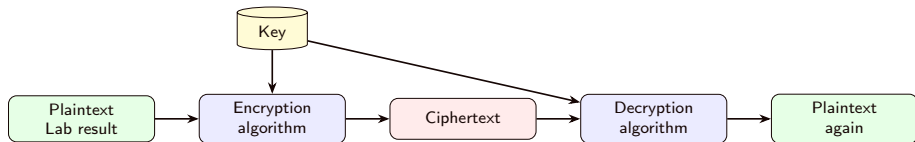
Concept

Encryption transforms plaintext into ciphertext. **Decryption** transforms ciphertext back into plaintext using the correct key.

Hospital example

Before sending a discharge letter to a referral clinic, the hospital encrypts it. If the message is intercepted, the attacker sees ciphertext rather than patient data.

Scheme: Encryption Flow



Reading the scheme

The algorithm may be public. The key is the secret that controls who can decrypt.

Classical Ciphers

Concept

Classical ciphers such as the Caesar cipher replace or move symbols according to a simple rule. They are useful for teaching, but not for real security.

Hospital example

Changing every letter in a patient's name by three positions would not protect the record. Anyone could reverse it once the pattern is recognised.

Why Simple Ciphers Fail

Concept

Substitution and transposition ciphers preserve patterns. Attackers can use language statistics, known formats, and repeated phrases to recover meaning.

Hospital example

Hospital messages often repeat phrases such as “patient ID”, “diagnosis”, or “lab result”. Repeated structure gives attackers clues if the cipher leaks patterns.

Recap: Cryptographic Foundations

Takeaways

- Cryptographic security should depend on protected keys, not secret algorithms.
- Encryption turns plaintext into ciphertext; decryption reverses it with the right key.
- Healthcare systems need secrecy, authenticity, integrity, and freshness.
- Simple historical ciphers fail because they leak patterns.

Symmetric Encryption

Section Context: Symmetric Encryption

What we are talking about

Symmetric encryption uses the **same secret key** for encryption and decryption. It is fast, widely deployed, and central to protecting stored and transmitted healthcare data.

Hospital lens

When St. Isidore encrypts database backups or file transfers, it commonly uses symmetric cryptography under the hood.

Symmetric Encryption

Concept

In symmetric encryption, sender and receiver share one secret key. Anyone with the key can decrypt the protected data.

Hospital example

The backup system encrypts nightly EHR backups with a hospital-controlled key. Recovery is possible only if that key remains available and protected.

Components of a Symmetric System

- **Plaintext:** original data.
- **Encryption algorithm:** transforms the plaintext.
- **Secret key:** controls the transformation.
- **Ciphertext:** encrypted output.
- **Decryption algorithm:** reverses the process with the same key.

Hospital example

The plaintext is an EHR export; the key is stored in a key-management system; the ciphertext is the encrypted backup file.

Two Requirements for Security

Concept

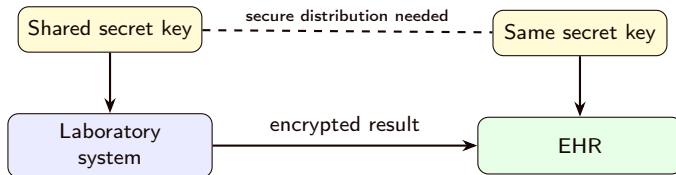
A symmetric system needs both a **strong algorithm** and **secure key handling**.

- The algorithm should resist cryptanalytic and brute-force attacks.
- The key must be generated, distributed, stored, rotated, and retired securely.

Hospital example

AES is not enough if the encryption key is stored in a shared spreadsheet or left on the same server as the data it protects.

Scheme: Symmetric Key Sharing



Takeaway

The difficult part is often not encryption itself, but getting the key safely to the right systems.

Cryptanalytic Attacks

Concept

Cryptanalysis tries to exploit weaknesses in the algorithm, message structure, or available plaintext/ciphertext examples.

Hospital example

If every exported report begins with the same header, a weak encryption mode may reveal patterns that help an attacker reason about the protected files.

Brute-Force Attacks

Concept

Brute force tries possible keys until the output looks like meaningful plaintext. Longer keys make exhaustive search infeasible.

Hospital example

If archived patient files were encrypted with an obsolete short key, an attacker with copied ciphertext may be able to recover the records later.

DES and 3DES

Historical note

DES used 64-bit blocks and a 56-bit key. It became insecure against brute force; 3DES applied DES three times with longer effective keys, but at a performance cost.

Hospital example

Legacy medical devices may still support old cryptographic suites. St. Isidore should identify where DES or 3DES appears and plan migration.

How DES Works

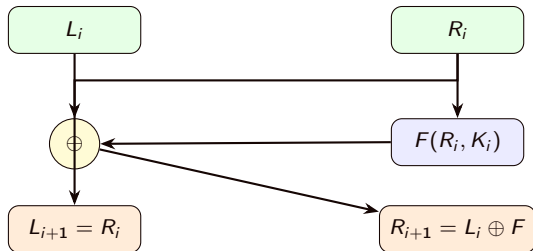
Mechanism

DES is a **Feistel block cipher**. Each 64-bit block is split into left and right halves. In each round, DES transforms one half with a round key, combines it with the other half using XOR, and then swaps the halves.

Hospital example

Think of one 8-byte fragment of a lab result. DES does not encrypt it in one step: it repeatedly mixes part of the fragment with key material so that changing one bit should spread through the block.

Scheme: DES Feistel Round



Reading the scheme

The right half becomes the next left half. The next right half is produced by mixing the old left half with a keyed transformation of the old right half.

Notebook: DES and 3DES

Practical example

Open `lesson-02/examples/02_des_3des_mechanics.ipynb` after the Feistel round scheme.

What students should notice

The notebook runs real DES-CBC and 3DES, then uses a small toy Feistel network to show why decryption works by applying round keys in reverse order.

Modern standard

The Advanced Encryption Standard is a symmetric block cipher with 128-bit blocks and key sizes of 128, 192, or 256 bits [National Institute of Standards and Technology, 2023].

Hospital example

AES is commonly used to encrypt backups, databases, disks, VPN traffic, and secure application channels in healthcare environments.

How AES Works

Mechanism

AES treats each 128-bit block as a 4-by-4 byte matrix called the **state**. It first mixes in key material, then repeats a round structure: **SubBytes**, **ShiftRows**, **MixColumns**, and **AddRoundKey**. The final round omits **MixColumns**.

Hospital example

For an encrypted backup, AES processes block after block of patient data. A safe mode of operation also makes sure repeated or changed backup chunks do not create predictable results.

AES Round Operations

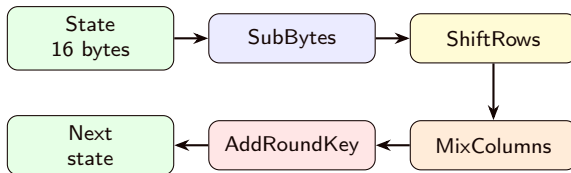
Algorithmic view

- ➊ **SubBytes**: replace each byte through a non-linear lookup table.
- ➋ **ShiftRows**: rotate rows so bytes move to new columns.
- ➌ **MixColumns**: combine bytes inside each column.
- ➍ **AddRoundKey**: XOR the state with round-key bytes.

Hospital example

If one byte changes in a medication record block, the substitutions and mixing spread that change through the block across later rounds.

Scheme: AES Round



Reading the scheme

AES security comes from repeating simple operations many times with different round keys.

Recap: Symmetric Encryption

Takeaways

- Symmetric encryption is fast and widely used.
- Security depends on strong algorithms and strong key management.
- DES is obsolete; 3DES is legacy; AES is the modern standard.
- A block cipher still needs a safe mode when used on real messages.
- Key exposure compromises every message protected with that key.

Blocks, Streams, and Modes

Section Context: Blocks, Streams, and Modes

What we are talking about

Encryption algorithms must process real data: files, messages, streams, and databases. This section explains why the way data is split and processed matters.

Hospital lens

St. Isidore encrypts long files, short alerts, real-time connections, and database fields. Different uses require different cryptographic constructions.

Block Ciphers

Concept

A **block cipher** encrypts fixed-size blocks of data. AES, for example, uses 128-bit blocks.

Hospital example

An encrypted backup file is divided into many blocks. The mode of operation determines how those blocks are combined and protected.

Modes of Operation

Concept

A block cipher such as AES only defines how to encrypt **one fixed-size block**. A **mode of operation** defines how to use that block cipher safely across longer messages.

Hospital example

An EHR backup is much longer than one AES block. The mode decides how each encrypted block relates to the previous block, to randomness, and sometimes to an authentication tag.

Electronic Codebook (ECB)

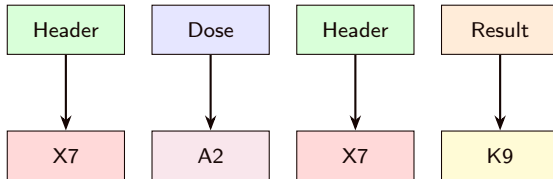
Concept

ECB encrypts equal plaintext blocks into equal ciphertext blocks under the same key. This leaks patterns and is not suitable for most real-world protection.

Hospital example

If many records start with the same structured header, ECB can reveal that repetition even though the content is encrypted.

Scheme: ECB Pattern Leakage



Reading the scheme

Repeated plaintext blocks produce repeated ciphertext blocks. The attacker sees structure.

CBC and GCM

Two safer directions

Cipher Block Chaining (CBC) uses an initialization vector and chains blocks to hide direct repetition. **Galois/Counter Mode (GCM)** is an authenticated-encryption mode: it encrypts data and computes a tag that detects tampering.

Hospital example

For St. Isidore, CBC can hide repeated backup structure when used correctly, but GCM is preferable for many messages because changed patient data or metadata will fail authentication.

Notebook: AES Modes

Practical example

Open the AES modes notebook in `lesson-02/examples:`
`03_aes_modes_authenticated_encryption.ipynb`

What students should notice

The notebook shows that AES-ECB leaks repeated blocks, AES-CBC hides those repetitions, and AES-GCM adds authentication so tampering is detected.

Stream Ciphers

Concept

A **stream cipher** generates a keystream and combines it with plaintext, often byte by byte or bit by bit.

Hospital example

Real-time encrypted communication, such as secure web traffic, may use constructions that behave like a protected stream rather than a static file encryption process.

Stream Cipher Safety

Key point

A stream cipher is only safe when the same key stream is not reused. In practice this means **never reuse the same key and nonce together**.

Nonce

A **nonce** is a value used once with a key. It does not always need to be secret, but it must follow the algorithm's uniqueness or randomness requirements.

Hospital example

If two telemetry messages from an infusion pump reuse the same stream, an attacker can compare the ciphertexts and learn how the clinical messages differ.

Notebook: Stream Encryption

Practical example

Open `lesson-02/examples/04_stream_cipher_chacha20.ipynb` after the stream cipher safety slide.

What students should notice

The notebook encrypts telemetry-like messages with ChaCha20 and then deliberately reuses a nonce. The XOR of ciphertexts reveals the XOR of plaintexts.

Block vs Stream Uses

Approach	Typical strength	Hospital examples
Block cipher	Good for structured data and files when used with safe modes	Backups, databases, file transfers
Stream cipher	Good for continuous communication when nonces and keystreams are safe	Secure channels, web sessions, VPN traffic

Important

Both approaches can be secure or insecure depending on the algorithm, mode, keys, nonces, and implementation.

Recap: Blocks, Streams, and Modes

Takeaways

- Block ciphers process fixed-size blocks.
- Stream ciphers protect data as a continuous flow.
- ECB is dangerous because it leaks repetition.
- Correct modes, nonces, and implementation details are part of security.

Authentication and Hashes

Section Context: Authentication and Hashes

What we are talking about

Encryption protects confidentiality, but active attacks require integrity and authentication. This section explains MACs and hash functions.

Hospital lens

When a pharmacy order arrives, the hospital must know not only that it was private, but also that it is genuine, unchanged, recent, and in the right sequence.

Message Authentication

Concept

A message is authentic when the receiver can verify its source and detect changes to its content. Good authentication can also check sequence and freshness.

Hospital example

The EHR should reject a lab result if it was modified, replayed from yesterday, or sent by a system pretending to be the laboratory.

Why Encryption Alone Is Not Enough

Concept

Confidentiality does not automatically imply integrity. Some encrypted data can still be reordered, replayed, or tampered with unless authentication is included.

Hospital example

If encrypted medication-order blocks can be rearranged without detection, the receiver may decrypt valid-looking but clinically wrong content.

Message Authentication Code

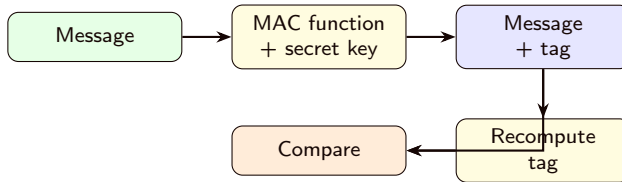
Concept

A **Message Authentication Code** (MAC) is a short tag computed from a message and a shared secret key. The receiver recomputes the tag and compares it.

Hospital example

The lab system attaches a MAC to each result message. The EHR verifies the MAC before accepting the result into the patient record.

Scheme: MAC Verification



Takeaway

If the tags match, the receiver gains confidence that the message came from someone with the key and was not altered.

Hash Functions

Concept

A **hash function** maps data of variable length to a fixed-length digest. A secure hash acts like a fingerprint of the input.

Hospital example

The hospital computes a hash of a software update before installation. If the downloaded file has changed, the hash will not match the expected value.

Properties of Secure Hashes

- **Preimage resistance:** given a digest, it is infeasible to find a matching input.
- **Second-preimage resistance:** given one input, it is infeasible to find a different input with the same digest.
- **Collision resistance:** it is infeasible to find any two different inputs with the same digest.

Hospital example

These properties help protect password storage, file-integrity monitoring, and digital signatures.

Hashing Passwords

Concept

Systems should store password verifiers, not plaintext passwords. In practice this requires password-hashing schemes with salts and work factors, not a bare fast hash.

Hospital example

If an attacker steals the staff account database, salted password hashes make password recovery harder than if plaintext passwords were stored.

File Integrity Monitoring

Concept

Hash values can help detect whether important files changed. The reference hashes must be protected from attackers.

Hospital example

St. Isidore stores trusted hashes of critical EHR configuration files. A nightly check alerts IT if malware modifies them.

Standard family

The Secure Hash Standard defines SHA algorithms used in many security applications [National Institute of Standards and Technology, 2015]. Algorithm choice matters because older hashes may become weak over time.

Hospital example

The hospital prefers modern SHA-2 or SHA-3 based mechanisms where appropriate, and avoids legacy uses of broken hashes in certificates or signatures.

How SHA Works

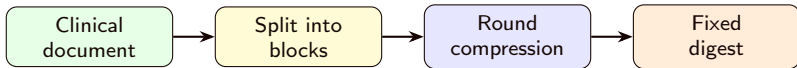
Algorithm idea

SHA algorithms process data in blocks. Each block updates an internal state through many rounds of bit operations. At the end, the final state becomes the fixed-length **digest**.

Hospital example

If a radiology report changes from “no fracture” to “fracture”, SHA-256 produces a completely different digest. The digest does not hide the report; it detects whether the exact bytes changed.

Scheme: SHA Digest



Important

SHA is **not encryption**: there is no decryption key and no way to recover the original message from the digest.

Notebook: Hashes, HMAC, and Passwords

Practical example

Open `lesson-02/examples/05_hashes_hmac_passwords.ipynb` after the SHA slide.

What students should notice

The notebook compares file hashes, verifies an HMAC on a lab message, and derives a salted password verifier. The same digest idea appears in different security roles.

Recap: Authentication and Hashes

Takeaways

- Encryption alone does not fully protect against active attacks.
- MACs authenticate messages using a shared secret key.
- Hash functions provide fixed-length fingerprints of data.
- Secure hashes support passwords, file checks, MACs, and digital signatures.

Public-Key Cryptography

Section Context: Public-Key Cryptography

What we are talking about

Public-key cryptography uses a pair of keys: one public and one private. It changes how systems solve confidentiality, authentication, signatures, and key distribution.

Hospital lens

St. Isidore uses public-key cryptography when browsers validate the patient portal certificate, when VPN sessions establish keys, and when signed software updates are verified.

Asymmetric Keys

Concept

Each participant has a **public key** that can be shared and a **private key** that must stay secret. What one key does, the paired key can verify or reverse, depending on the scheme.

Hospital example

The patient portal publishes a certificate containing its public key. The matching private key stays protected on the server or in a hardware security module.

Confidentiality with Public Keys

Concept

To send confidential data to Alice, Bob encrypts using Alice's public key. Only Alice's private key can decrypt.

Hospital example

An external clinic can encrypt a referral package so that only St. Isidore's receiving service can open it.

Authentication with Private Keys

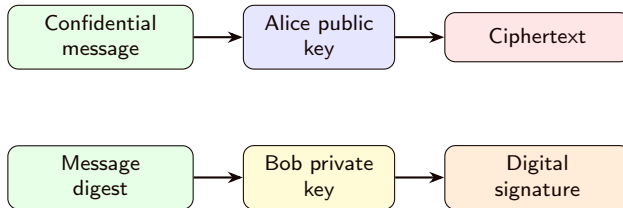
Concept

To prove origin, Bob signs with his private key. Anyone with Bob's public key can verify that the signature matches.

Hospital example

A signed software update proves that the update came from the trusted vendor and was not modified after signing.

Scheme: Public-Key Uses



Reading the scheme

Public-key encryption and digital signatures use key pairs differently. The goal determines which key is used.

Families of Public-Key Algorithms

What changes between algorithms

Public-key algorithms are not interchangeable names. Each family is built around a hard mathematical problem and is usually designed for one main purpose: **encryption**, **digital signature**, or **key agreement**.

Hospital example

The patient portal certificate may use one algorithm to sign its identity, while the VPN handshake uses another algorithm to agree on fresh session keys. Both are public-key cryptography, but they do different jobs.

RSA: Trapdoor Computation

Algorithm idea

RSA is based on modular arithmetic with a public modulus. The public key can transform data in one direction, while the private key provides the **trapdoor** needed to reverse or sign that transformation.

Hospital example

An external clinic can encrypt a small session key with St. Isidore's RSA public key. Only the hospital private key can unwrap it. The same RSA key family can also sign messages when used with a signature padding scheme.

RSA in Practice

Important distinction

RSA should not be used to encrypt large clinical files directly. It is usually used to protect small values, such as a symmetric session key, or to create digital signatures.

Hospital example

For an imaging report, St. Isidore encrypts the file with AES, then uses RSA only to protect the AES key. This is the digital-envelope pattern used later in the lesson.

Diffie-Hellman Key Agreement

Concept

Diffie-Hellman allows two parties to establish a shared secret over an insecure channel [Diffie and Hellman, 1976]. By itself, basic Diffie-Hellman does not authenticate who is on the other side.

Hospital example

A doctor connects to the VPN from home. The protocol can agree on session keys, but certificates and authentication are needed to prevent an attacker from impersonating the hospital.

How Diffie-Hellman Works

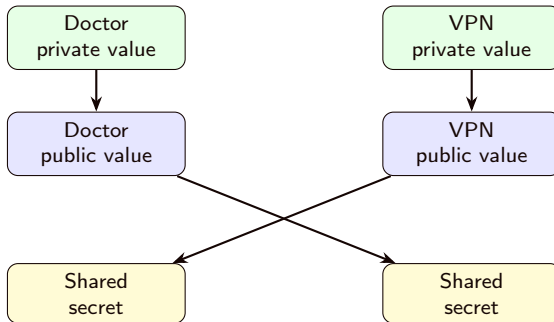
Algorithm idea

Each side creates a private random value and publishes a related public value. The two public values can be exchanged openly. Combining **my private value** with **your public value** gives the same shared secret on both sides.

Hospital example

The doctor's laptop and the VPN gateway exchange public handshake values. An observer can see those values, but cannot feasibly compute the final session key without one of the private values.

Scheme: Diffie-Hellman



Reading the scheme

The shared secret is not transmitted. Each side derives it locally from one private value and one received public value.

Notebook: Diffie-Hellman

Practical example

Open `lesson-02/examples/07_diffie_hellman_randomness.ipynb` after the Diffie-Hellman slide, then return to it again in the randomness section.

What students should notice

The doctor and the hospital compute the same shared secret without sending that secret over the network. The notebook then derives a session key from it.

DSS and DSA: Signature Only

Algorithm idea

The Digital Signature Standard (DSS) defines approved ways to create digital signatures. DSA is a signature algorithm from that family. It does **not** encrypt data and it does **not** establish shared keys.

Hospital example

A software vendor can sign a pacemaker gateway firmware update. The hospital verifies the signature before installation, but the signature itself does not hide the update contents.

How DSA Is Used

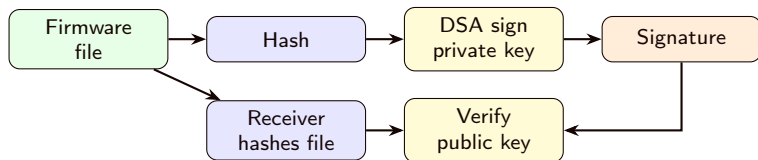
Signing flow

DSA signs a **hash** of the message, not the whole message directly. The private key creates a signature value; the public key verifies whether that signature matches the message hash.

Hospital example

The vendor signs the hash of a firmware package. St. Isidore hashes the downloaded package again and verifies the signature with the vendor public key before installing it.

Scheme: DSA Signature



Takeaway

DSA gives authenticity and integrity, but not confidentiality.

Algorithm Families: Recap Map

Algorithm family	Digital signature	Key agreement	Encryption
RSA	Yes	Legacy key transport	Yes, for small values
Diffie-Hellman	No	Yes	No
DSS / DSA	Yes	No	No

Important

Modern protocols combine these families with symmetric encryption. The public-key step establishes identity or keys; AES-like symmetric encryption protects the bulk data.

Recap: Public-Key Cryptography

Takeaways

- Public-key cryptography uses key pairs, not one shared secret.
- Public keys can be shared; private keys must be protected.
- It supports encryption, signatures, and key establishment.
- It usually works together with symmetric encryption in real systems.

Signatures, Certificates, and Envelopes



What we are talking about

Public keys are useful only when we can trust whose key they are. This section connects digital signatures, certificates, certificate authorities, and hybrid encryption.

Hospital lens

The hospital must trust that the patient portal certificate belongs to St. Isidore, that vendor updates are signed by the vendor, and that encrypted messages reach the intended recipient.

Digital Signatures

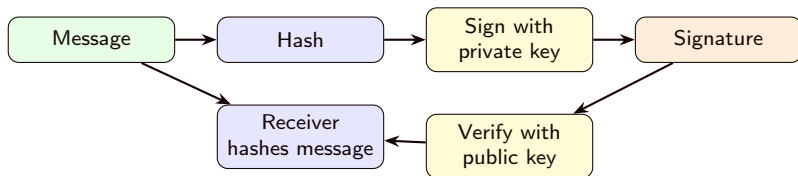
Concept

A digital signature is usually created by hashing a message and signing the hash with the sender's private key.

Hospital example

The pharmacy service signs a formulary update. The EHR verifies the signature before using the new medication rules.

Scheme: Digital Signature



Takeaway

Signatures provide origin authentication and integrity, but not confidentiality by themselves.

Certificates

Concept

A certificate binds a public key to an identity and is signed by a trusted certificate authority. It includes identity information, the public key, issuer information, and validity period.

Hospital example

When a patient opens the portal, the browser checks that the portal certificate is valid and issued for the correct hospital domain.

Why Certificates Are Needed

Threat

Without certificates, an attacker could publish a fake public key and pretend to be the hospital, a doctor, or a vendor.

Hospital example

If a fake portal key is accepted, patients may encrypt login credentials and health messages for the attacker instead of St. Isidore.

Digital Envelopes

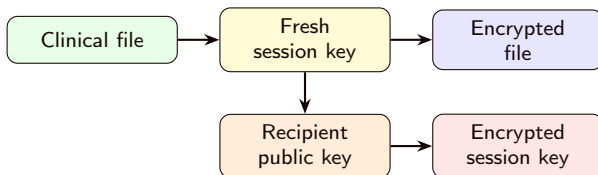
Concept

A **digital envelope** combines symmetric and public-key cryptography: encrypt the message with a fresh symmetric key, then encrypt that key with the recipient's public key.

Hospital example

The hospital sends a large imaging report to an external specialist. The file is encrypted with a fast session key; the session key is protected with the specialist's certified public key.

Scheme: Digital Envelope



Reading the scheme

Hybrid encryption is efficient: symmetric cryptography protects the data; public-key cryptography protects the temporary key.

Notebook: RSA and Digital Envelopes

Practical example

Open
`lesson-02/examples/06_rsa_signatures_digital_envelopes.ipynb`
after the digital envelope scheme.

What students should notice

The notebook signs a prescription approval with RSA, then encrypts a clinical file with a fresh AES key and wraps that key with the recipient's RSA public key.

Recap: Signatures, Certificates, and Envelopes

Takeaways

- Digital signatures authenticate origin and detect modification.
- Certificates bind public keys to identities.
- Certificate authorities make public-key trust scalable.
- Digital envelopes combine efficient symmetric encryption with public-key key protection.

Keys and Randomness

Section Context: Keys and Randomness

What we are talking about

Cryptography depends on keys and unpredictable values. Strong algorithms fail if keys are leaked, reused incorrectly, generated weakly, or never rotated.

Hospital lens

St. Isidore needs keys for backups, VPN sessions, portal certificates, signed updates, disk encryption, and secure device communication.

Key Management

Concept

Key management covers generation, distribution, storage, use, rotation, backup, revocation, and destruction of cryptographic keys [Barker, 2020].

Hospital example

If the backup encryption key is lost, recovery fails. If the key is stolen, confidentiality fails. Both availability and confidentiality depend on key management.

Random Numbers in Cryptography

Concept

Randomness is used for key generation, session keys, stream ciphers, nonces, handshakes, and replay prevention.

Hospital example

When a clinician opens an HTTPS session with the EHR, random values help create fresh session keys and prevent reuse of old traffic.

Uniformity and Independence

Concept

A random sequence should have a roughly uniform distribution and should not allow one value to be predicted from previous values.

Hospital example

If a medical device generates predictable session keys after reboot, an attacker who observes one session may predict the next one.

TRNG and PRNG

Concept

A **true random number generator** uses a non-deterministic physical source. A **pseudorandom generator** is deterministic but can be suitable when properly designed and seeded.

Hospital example

A secure server may seed a cryptographic PRNG from hardware randomness, then use it to generate TLS session keys for many portal connections.

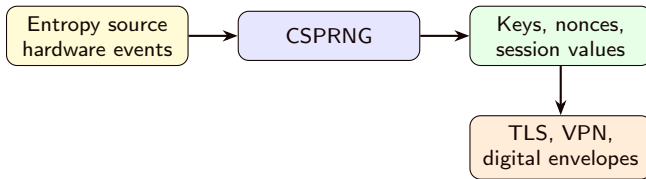
Concept

A cryptographically secure pseudorandom number generator (**CSPRNG**) is a PRNG designed so that observing previous outputs does not make future outputs feasible to predict.

Hospital example

The patient portal should use a CSPRNG for session identifiers, reset tokens, and cryptographic nonces. A normal simulation-oriented generator is not enough.

Scheme: Cryptographic Randomness



Takeaway

Predictable randomness can silently break otherwise strong cryptography.

Notebook: Randomness

Practical example

Reopen `lesson-02/examples/07_diffie_hellman_randomness.ipynb` after the randomness scheme.

What students should notice

The notebook contrasts cryptographic randomness with a deterministic seeded generator. Predictable values repeat; secure tokens do not.

TLS as a Preview

Connection

TLS combines many ideas from this lesson: certificates, public-key authentication, key agreement, symmetric encryption, MACs or authenticated encryption, and fresh random values [Rescorla, 2018].

Hospital example

When patients use the portal, TLS helps them verify the hospital site, protects credentials in transit, and creates fresh keys for the session.

Recap: Keys and Randomness

Takeaways

- Key management is part of cryptographic security, not an administrative afterthought.
- Randomness supports keys, nonces, session setup, and replay protection.
- PRNGs must be cryptographically strong and properly seeded.
- TLS shows how encryption concepts combine in real network security.

Connecting the Concepts

The full picture

Encryption protects confidentiality, but healthcare security also needs authentication, integrity, key management, certificates, and operational procedures.

St. Isidore Hospital

A secure lab-result workflow may use TLS for transport, certificates for server identity, symmetric session keys for speed, message authentication for integrity, and logs for accountability.

What Encryption Does Not Solve

Important boundary

Encryption does not fix weak access control, stolen endpoints, bad workflows, missing backups, or users who are tricked into approving the wrong action.

Hospital example

If an attacker logs in as a real clinician, encryption may protect the network path while the EHR still reveals records to the compromised account.

Bridge to Later Lessons

What comes next

Later lessons will place these mechanisms inside real systems and regulations.

- **Basic networking:** where TLS, VPNs, and encrypted channels sit.
- **Access management:** who can use keys and decrypt data.
- **GDPR:** why encryption, pseudonymisation, and breach risk matter for personal data.
- **Operations:** how keys, certificates, backups, and incidents are managed.

Doubts? Mail me!



g.pisano@unibo.it

Cryptographic Foundations for Healthcare Systems

Giuseppe Pisano
g.pisano@unibo.it

Healthcare Data Privacy and Security

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

References I

[Barker, 2020] Barker, E. (2020).

Recommendation for key management: Part 1 – general.

Special Publication 800-57 Part 1 Revision 5, National Institute of Standards and Technology

DOI:10.6028/NIST.SP.800-57pt1r5.

[Diffie and Hellman, 1976] Diffie, W. and Hellman, M. E. (1976).

New directions in cryptography.

IEEE Transactions on Information Theory, 22(6):644–654

DOI:10.1109/TIT.1976.1055638.

[Kerckhoffs, 1883] Kerckhoffs, A. (1883).

La cryptographie militaire.

Journal des sciences militaires, 9:5–38

[National Institute of Standards and Technology, 2015] National Institute of Standards and Technology (2015).

Secure hash standard (shs).

Federal Information Processing Standards Publication 180-4, National Institute of Standards and Technology

DOI:10.6028/NIST.FIPS.180-4.

References II

- [National Institute of Standards and Technology, 2023] National Institute of Standards and Technology (2023).
Advanced encryption standard (aes).
Federal Information Processing Standards Publication 197, National Institute of Standards and Technology
DOI:10.6028/NIST.FIPS.197-upd1.
- [Rescorla, 2018] Rescorla, E. (2018).
The transport layer security (tls) protocol version 1.3.
RFC 8446, Internet Engineering Task Force
DOI:10.17487/RFC8446.